Cryptography and Data Encryption Standard

Policy ID: STD-CRY-010 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Chief Information Security Architect	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This standard defines approved cryptographic algorithms, protocols, key-management practices, certificate requirements, password hashing, encryption-at-rest and encryption-in-transit controls. Cryptography must be implemented through reviewed libraries and centralized services where possible; custom cryptographic designs are prohibited without specialist review.

2. Scope

This standard applies to applications, endpoints, cloud services, databases, storage, backups, APIs, networks, VPNs, email/security gateways, mobile applications, embedded products, CI/CD systems, code signing, document signing, key stores, secrets management, and any system using cryptography to protect enterprise, customer, or personal data.

3. Governance, Accountability, and Roles

Security Architecture / Cryptography Owners. Maintain approved algorithms, key lengths, protocols, and exception criteria.

Engineering. Uses approved libraries, manages key references correctly, and avoids custom primitives/protocols.

Cloud/Infrastructure. Operates KMS/HSM, certificates, rotation, backup, and access separation.

System/Data Owners. Determine where encryption is required based on classification, threat, law, and contract.

4. Policy Rules and Mandatory Guidelines

- Restricted and Confidential data MUST be encrypted at rest when stored on portable devices, cloud/object storage, databases, backups, and other media according to classification requirements.
- Data transmitted over untrusted networks MUST be encrypted and integrity protected. TLS 1.3 is the default for new services. TLS 1.2 may be used for compatibility only with approved cipher suites and configuration. TLS 1.0, TLS 1.1, SSLv2, SSLv3, and plaintext protocols for sensitive data are prohibited.
- MD5 and SHA-1 MUST NOT be used for digital signatures, certificate signatures, password hashing, security-sensitive integrity, or new cryptographic designs. Non-security checksum use requires clear labeling and must not be represented as tamper protection.
- Passwords MUST be hashed using an approved memory-hard or adaptive function such as Argon2id, scrypt, or bcrypt with per-user unique salts and enterprise-approved parameters. General-purpose fast hashes such as SHA-256 alone are prohibited for password storage.

- AES with 128-bit keys is the minimum accepted symmetric strength for approved modern modes; AES-256 SHOULD be used for high-value long-lived data when supported. ECB mode is prohibited. Authenticated encryption modes such as AES-GCM or ChaCha20-Poly1305 SHOULD be used where appropriate.
- RSA keys smaller than 2048 bits are prohibited for enterprise security use. New designs SHOULD prefer at least RSA-3072 for longer-lived protection or approved elliptic-curve algorithms where interoperability and standards support them.
- Approved elliptic-curve cryptography MUST use well-established standardized curves and vetted libraries. Novel or custom curves require specialist approval.
- Private keys, symmetric master keys, signing keys, and high-value secrets MUST NOT be embedded in source code, images, mobile apps, client JavaScript, configuration repositories, or tickets.
- Cryptographic keys MUST have defined owners, purpose, scope, lifecycle, rotation/expiry, backup/recovery where appropriate, access control, and destruction process. Reusing a key for unrelated purposes is prohibited when it creates cross-domain risk.
- Production signing keys and high-value key-encryption keys SHOULD be generated and stored in HSM or managed KMS services that provide non-exportability, access logging, and separation of duties where feasible.
- Certificates MUST be issued by approved certificate authorities for their trust context. Self-signed certificates are prohibited for public production services and may be used internally only where explicit trust distribution and lifecycle management are controlled.
- Certificate and key expiry MUST be monitored with sufficient lead time to avoid outages. Manual calendar reminders alone are insufficient for critical production certificates.

5. Technical and Coding Constraints

- TLS servers MUST disable obsolete protocols, compression where vulnerable, weak ciphers, anonymous suites, and insecure renegotiation patterns. Server private keys MUST be protected by OS/KMS permissions and MUST NOT be broadly readable.
- Applications MUST validate certificate chains and hostnames. Disabling TLS certificate verification in production code, setting insecure trust-all handlers, or suppressing hostname checks is Strictly Prohibited.
- Nonce/IV requirements of cryptographic modes MUST be followed exactly. Reuse of a nonce under AES-GCM or other modes where reuse breaks security is prohibited.
- Random keys, tokens, nonces, password reset codes, and session identifiers MUST use cryptographically secure random-number generators. General-purpose PRNGs, timestamps, counters, or predictable UUID variants MUST NOT be used as security secrets.
- Application-level encryption MUST define key separation, integrity/authentication, versioning, and rotation. Encrypting data without integrity protection where tampering is plausible is not sufficient.
- Key derivation MUST use approved KDFs such as HKDF or PBKDF2 for appropriate contexts; direct truncation or hashing of human passwords into encryption keys is prohibited.
- Secrets at rest SHOULD be stored in enterprise secret-management services, not generic configuration databases. Access to decrypt/encrypt MUST be independently authorized where system design permits.
- Backups containing encrypted data MUST protect the keys needed for recovery without placing keys in the same failure domain as the encrypted backups when doing so would defeat ransomware or disaster-recovery objectives.
- Source code MUST use maintained cryptographic libraries provided by trusted platform/runtime or approved dependencies. Implementing custom AES, RSA, ECC, hashing, TLS, or random-number algorithms is prohibited except for approved research under isolated conditions.
- Cryptographic configuration MUST be included in security testing and configuration scanning, including checks for weak TLS, expiring certificates, hard-coded keys, and inappropriate algorithms.

6. Operational Control Requirements

- A cryptographic inventory SHOULD identify critical certificates, keys, algorithms, protocols, owners, systems, and expiry/rotation. The enterprise MUST maintain a migration capability for deprecated algorithms and post-quantum transition as standards and business risk evolve.
- Compromise or suspected exposure of a private key or secret requires immediate revocation/rotation and impact assessment. Encryption of data with a compromised key is not considered protective.
- Key destruction MUST be appropriate to the medium and architecture, including revocation/deletion of KMS key material where cryptographic erasure is used as a disposal control.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- Key/certificate inventory
- KMS/HSM access logs
- Rotation and expiry evidence
- Cryptographic exception register
- TLS configuration scans
- Secret-scanning results
- Key-compromise incident records

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Systems using prohibited cryptography may be blocked from production or network access. Security may require emergency certificate/key rotation or disable insecure protocols. Deliberate weakening of TLS, use of hard-coded production keys, or bypass of certificate validation may result in disciplinary action and mandatory incident assessment.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Cryptographic exceptions require a documented interoperability or legacy constraint, data classification, threat assessment, compensating controls, migration date, owner, and Security Architecture approval. Exceptions for obsolete protocols or weak algorithms MUST be time-limited and isolated; 'vendor only supports it' is not sufficient without a remediation plan.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports cryptographic use, key management, authentication information, information transfer, secure development, configuration, and protection of data.
NIST CSF 2.0	PR.DS data security; PR.AA authentication; PR.PS platform security; GV.RM risk governance; DE.CM monitoring for certificate/key misuse.
GDPR	Article 32 explicitly recognizes measures such as pseudonymization and encryption as relevant safeguards, with security calibrated to risk.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.